

Contrat de sous-traitance des données personnelles (DPA)

Modèle à relire et valider par un conseil juridique avant signature. Article 28 du RGPD. Les mentions [...] sont à compléter au moment de la contractualisation avec chaque client.

Entre les parties

Le Responsable de traitement (ci-après « le Responsable ») : [Dénomination du franchisé / de la structure cliente], [forme juridique], [SIRET], [adresse], représenté par [nom, qualité].

Le Sous-traitant (ci-après « le Sous-traitant ») : Anne-Lise Caillet, editrice de l'application **BATILIS**, [forme juridique], [SIRET], [adresse]. Contact protection des données : anne-lise.caillet@outlook.com

Article 1 — Objet

Le présent contrat, conclu en application de l'**article 28 du RGPD** et de la **loi n° 78-17 du 6 janvier 1978 modifiée** (Loi Informatique et Libertés), encadre les traitements de données à caractère personnel que le Sous-traitant réalise **pour le compte et sur les instructions du Responsable**, dans le cadre de la mise à disposition de l'application BATILIS.

Il complète le contrat de service principal liant les parties et prévaut, pour les questions de protection des données, en cas de contradiction.

Article 2 — Description du traitement

Élément	Description
Nature des opérations	Collecte (via saisie du Responsable), stockage, structuration, consultation, mise à disposition, hébergement, sauvegarde, suppression
Finalités	Fournir au Responsable les fonctionnalités de gestion de son activité (dossiers clients, artisans, rendez-vous, comptes-rendus, documents, facturation de ses propres prestations)
Durée	Durée du contrat de service ; suppression ou restitution en fin de contrat (art. 9)
Catégories de personnes	Clients finaux du Responsable et co-titulaires du foyer, artisans, apporteurs d'affaires

Élément	Description
Catégories de données	Identité, coordonnées, adresses, coordonnées bancaires (artisans), documents d'entreprise, contenus de rendez-vous et comptes-rendus, échanges

Le Responsable reconnaît qu'aucune donnée relevant des catégories particulières (art. 9 RGPD) ne doit être saisie dans les champs libres de l'application, et s'engage à sensibiliser ses utilisateurs en ce sens.

Article 3 — Obligations du Sous-traitant

Le Sous-traitant s'engage à :

1. **Traiter les données uniquement pour les finalités** prévues et **sur instruction documentée** du Responsable. Il ne réutilise en aucun cas les données pour ses propres finalités (notamment : statistiques produites à des fins commerciales, marketing, ou entraînement de modèles d'intelligence artificielle).
 2. **Garantir la confidentialité** : toute personne autorisée à traiter les données est soumise à une obligation de confidentialité.
 3. **Mettre en œuvre les mesures de sécurité** appropriées (article 32 RGPD) décrites à l'Annexe 1.
 4. **Respecter les conditions de recours à un sous-traitant ultérieur** (article 4 ci-dessous).
 5. **Aider le Responsable** à répondre aux demandes d'exercice des droits des personnes concernées (accès, rectification, effacement, etc.), compte tenu de la nature du traitement.
 6. **Aider le Responsable** à garantir le respect de ses obligations de sécurité, de notification de violation, et d'analyse d'impact le cas échéant (articles 32 à 36).
 7. **Notifier au Responsable toute violation de données** dans les meilleurs délais après en avoir pris connaissance, avec les informations nécessaires.
 8. **Selon le choix du Responsable, supprimer ou restituer** toutes les données à la fin de la prestation, et détruire les copies existantes, sauf obligation légale de conservation.
 9. **Mettre à disposition du Responsable** toute information nécessaire pour démontrer le respect de ses obligations et permettre des audits.
-

Article 4 — Sous-traitants ultérieurs

Le Responsable **autorise** le Sous-traitant à recourir aux sous-traitants ultérieurs suivants pour l'exécution du service :

Sous-traitant ultérieur	Service	Localisation	Encadrement à mettre en place
Supabase	Base de données, authentification, stockage	Union européenne (Irlande)	Données au repos dans l'UE ; DPA du prestataire à formaliser
Vercel	Hébergement, exécution, mesure d'audience/performance	États-Unis (fonctions serveur)	DPA + Clauses Contractuelles Types à formaliser
Anthropic (Claude)	Génération assistée de comptes-rendus et courriers	API du prestataire	DPA à signer ; option de non-conservation des données à activer
Google	Synchronisation calendrier (si activée)	Services Google	Engagements contractuels Google ; jetons d'accès chiffrés au repos
Apple / iCloud	Synchronisation calendrier (si activée)	Services Apple	Mot de passe d'application chiffré au repos

Statut des garanties : le Sous-traitant s'engage à formaliser, avec chacun de ces prestataires, les accords de traitement (DPA) et garanties de transfert appropriés, et — pour le prestataire d'IA — à demander l'activation de la non-conservation des données. Ces éléments constituent des **engagements à mettre en œuvre** et non des faits déjà acquis à la date du présent contrat.

Le Sous-traitant s'engage à **informer le Responsable de tout changement** prévu concernant l'ajout ou le remplacement d'un sous-traitant ultérieur, laissant au Responsable la possibilité d'émettre des objections.

Chaque sous-traitant ultérieur est tenu aux mêmes obligations de protection des données que celles définies au présent contrat.

Article 5 — Transferts hors Union européenne

Le stockage principal des données est situé dans l'**Union européenne** (Irlande).

L'**exécution de l'application** (Vercel) implique un traitement sur des serveurs situés aux **États-Unis**. De même, le recours à l'assistance IA (Anthropic) peut impliquer un traitement

hors UE. Ces transferts sont encadrés par les **Clauses Contractuelles Types** de la Commission européenne et/ou les accords de traitement des données des prestataires concernés.

Article 6 — Sécurité et localisation

Les mesures techniques et organisationnelles sont décrites en **Annexe 1**. Elles incluent notamment le cloisonnement strict des données par organisation (Row-Level Security), le chiffrement des secrets d'accès au repos, l'authentification sécurisée et la gestion des accès par rôle.

Article 7 — Sort des données en fin de contrat

À la fin de la prestation, le Responsable choisit :

- soit la **restitution** des données dans un format exploitable ;
- soit la **suppression** définitive des données et de leurs copies.

Sauf obligation légale de conservation, cette opération intervient dans un délai de [X jours] après la fin du contrat.

Article 8 — Responsabilité

Chaque partie répond des dommages causés par un manquement à ses obligations au titre du RGPD, dans les conditions prévues par l'article 82 du Règlement.

Annexe 1 — Mesures techniques et organisationnelles de sécurité

- **Cloisonnement par organisation** : mécanisme de sécurité au niveau de la base de données (Row-Level Security) appliqué sur l'ensemble des tables, garantissant que chaque organisation n'accède qu'à ses propres données. Cloisonnement de la visibilité des agendas (personnel / partagé) au niveau de chaque enregistrement.
 - **Chiffrement des secrets** : les secrets d'accès aux calendriers connectés — mot de passe d'application CalDAV (iCloud) et jetons d'accès Google — sont **chiffrés au repos** (AES-256-GCM), et protégés en outre par le cloisonnement RLS et un accès restreint.
 - **Authentification** : mots de passe hachés, gestion des sessions par le service d'authentification, contrôle d'accès par rôle.
 - **Contrôle d'accès** : rôles déterminant les droits ; possibilité de désactiver un compte.
 - **Stockage documentaire** : accès aux fichiers via des URLs signées à durée limitée.
 - **Hébergement** : base de données dans l'Union européenne (Irlande).
-

Signatures

Le Responsable

Le Sous-traitant

Nom :

Anne-Lise Caillet

Qualité :

Éditrice de BATILIS

Date :

Date :

Signature :

Signature :